

PROYECTO 7: WAF SHIELD CLOUD – SEGURIDAD PERIMETRAL PARA APLICACIONES EN LA NUBE

1. Nombre del proyecto

WAF Shield Cloud – Implementación de Seguridad Perimetral para Aplicaciones en la Nube

2. Duración total del proyecto

El proyecto está definido para una duración de **10 semanas**, distribuidas en fases, según el plan de trabajo semanal: desde el **onboarding y planificación**, hasta la **entrega profesional del prototipo funcional**.

3. Fases o etapas del proyecto

Resumen de fases

- **Fase 0 – Onboarding y planificación**
- **Fase 1 – Análisis del entorno, riesgos y diseño de la solución**
- **Fase 2 – Implementación del entorno protegido y configuración del WAF**
- **Fase 3 – Validación de seguridad, pruebas de tráfico y refinamiento**
- **Fase 4 – Cierre, documentación y entrega profesional**

4. Tipo de aplicación

Prototipo de **arquitectura de seguridad perimetral cloud** orientada a proteger una aplicación web desplegada en la nube, compuesto por:

- Una **aplicación web o servicio expuesto**.
- Un **WAF (Web Application Firewall)** o capa de filtrado perimetral.
- Reglas de seguridad para mitigar amenazas comunes.
- Registro y análisis de eventos de tráfico.
- Dashboard o consola de monitoreo de incidentes y solicitudes bloqueadas.

4.1 Infraestructura propuesta

Componentes sugeridos

- **Aplicación web de prueba** desplegada en cloud.

- **WAF administrado o autogestionado**, según capacidades del equipo.
- **Proxy inverso** o capa perimetral segura.
- **Servicio de DNS/CDN/WAF**, si el equipo decide usar proveedor administrado.
- **Repositorio GitHub** para control de versiones.
- **Bitácora y documentación técnica** de configuración, pruebas e incidentes.

Tecnologías posibles

- **Cloudflare WAF**
- **AWS WAF**
- **Azure Web Application Firewall**
- **Google Cloud Armor**
- **Nginx + ModSecurity + OWASP CRS**
- **Aplicación web de prueba en Vercel, Render, Netlify, Firebase Hosting o VM**
- **Logs en consola, archivos, Google Sheets, dashboards básicos o panel propio**

5. Propósito del proyecto

Atender la necesidad de la **Unidad de Seguridad Digital y Protección de Servicios Cloud (USDPS-SC)** de contar con un prototipo funcional que permita **proteger una aplicación web expuesta en internet**, mediante la implementación de una estrategia de **seguridad perimetral cloud**, con énfasis en el uso de **WAF**, reglas de filtrado, monitoreo de tráfico sospechoso y documentación de eventos relevantes.

La solución debe permitir:

- Reducir la exposición a amenazas web comunes.
- Filtrar tráfico malicioso antes de llegar a la aplicación.
- Proteger formularios, rutas sensibles y endpoints críticos.
- Generar evidencias de bloqueo o mitigación.
- Demostrar buenas prácticas de **ciberseguridad cloud** y protección perimetral.

6. Objetivos del proyecto

6.1 Objetivo operativo de la estancia

Que el equipo de estudiantes diseñe, implemente y documente un prototipo de **seguridad perimetral cloud**, capaz de proteger una aplicación web mediante el uso de un **WAF** y controles

asociados, trabajando de forma asincrónica, en equipo, y gestionando de forma responsable los recursos tecnológicos empleados.

6.2 Objetivos específicos

- Analizar riesgos y vectores de ataque comunes en aplicaciones web expuestas.
- Diseñar una arquitectura básica de seguridad perimetral para un servicio cloud.
- Implementar un WAF o mecanismo equivalente de protección.
- Configurar reglas para filtrar tráfico malicioso o anómalo.
- Validar el comportamiento del sistema ante solicitudes legítimas y maliciosas.
- Documentar la solución, sus pruebas, eventos y recomendaciones de mejora.

7. Entidad receptora

Cliente (Entidad receptora):

Unidad de Seguridad Digital y Protección de Servicios Cloud (USDP-SC) de la Universidad Nova Digital, responsable de promover buenas prácticas de **protección de aplicaciones web**, endurecimiento perimetral y reducción de exposición frente a amenazas de internet.

Sector: Ciberseguridad / Servicios Digitales

Unidad ejecutora: Unidad de Proyectos ESIT – Línea de Ciberseguridad Cloud y Protección Perimetral

8. Escenario

8.1 Contexto de la organización

La **Universidad Nova Digital**, institución ficticia con enfoque en innovación tecnológica, transformación digital y operación académica basada en servicios en la nube, ha incrementado durante los últimos años la cantidad de plataformas accesibles desde internet: portales estudiantiles, formularios web, micrositios académicos, paneles administrativos, APIs y aplicaciones de apoyo institucional. Este crecimiento ha mejorado la disponibilidad de servicios, pero también ha ampliado significativamente la **superficie de ataque** de la organización.

Muchas de estas aplicaciones son consumidas por estudiantes, docentes, personal administrativo y usuarios externos, por lo que se encuentran permanentemente expuestas a tráfico legítimo y,

potencialmente, a tráfico malicioso. Entre los riesgos más relevantes se encuentran los intentos de explotación de vulnerabilidades web comunes, exploración automatizada de rutas, abuso de formularios, inyección de entradas maliciosas, scraping, intentos de denegación de servicio a pequeña escala y reconocimiento de infraestructura. En escenarios reales, una aplicación sin protección perimetral puede convertirse rápidamente en una puerta de entrada para afectaciones técnicas, operativas y reputacionales.

La USDP-SC ha identificado que varias soluciones web institucionales dependen únicamente de la seguridad interna de la aplicación, sin incorporar una capa perimetral robusta que permita inspeccionar, filtrar, registrar y responder a patrones de tráfico sospechoso antes de que estos lleguen al servicio principal. Esta situación limita la capacidad preventiva de la organización y la obliga a reaccionar demasiado tarde, cuando el problema ya tocó la puerta y hasta se sentó en la sala.

Por ello, la institución desea explorar un enfoque de **ciberseguridad cloud** basado en **WAF y seguridad perimetral**, que permita establecer una primera línea de defensa frente a amenazas comunes, reforzar la protección de aplicaciones y generar una cultura técnica orientada al diseño seguro de servicios publicados en internet.

8.2 Situación actual o problema detectado

Actualmente, la organización no cuenta con un esquema consistente y estandarizado de **protección perimetral para aplicaciones web**. Algunas aplicaciones se encuentran publicadas directamente, con controles mínimos o dependientes exclusivamente del framework o de la configuración del servidor. Esta situación genera múltiples debilidades:

- No existe una capa uniforme de inspección y filtrado del tráfico HTTP/HTTPS.
- Las solicitudes sospechosas pueden llegar directamente a la aplicación.
- No se dispone de reglas centralizadas para bloquear patrones comunes de ataque.
- La visibilidad sobre el tráfico anómalo o malicioso es limitada.
- No hay suficientes evidencias estructuradas para análisis posterior de incidentes.
- La organización no cuenta con un prototipo demostrativo que permita formar a futuros profesionales en este ámbito.

Esta carencia impide responder con claridad preguntas clave como:

- ¿Qué tipo de tráfico anómalo está llegando a la aplicación?
- ¿Qué rutas o recursos son más atacados o explorados?
- ¿Qué solicitudes deberían bloquearse antes de llegar al backend?

- ¿Qué tan efectiva es una capa WAF en un escenario de despliegue cloud?
- ¿Cómo documentar evidencias de mitigación de ataques web comunes?

En síntesis, la ausencia de una solución perimetral convierte a la aplicación expuesta en un objetivo con defensa parcial: funcional, sí; confiable, quizá; endurecida, todavía no.

8.3 Propuesta de valor

La solución **WAF Shield Cloud** propone:

- Desplegar una aplicación web de prueba en la nube.
- Protegerla mediante un **WAF** o solución equivalente.
- Configurar reglas de seguridad frente a amenazas comunes.
- Validar el comportamiento del sistema ante tráfico legítimo y malicioso.
- Generar registros y evidencias del funcionamiento del control perimetral.
- Documentar una arquitectura replicable de **seguridad cloud** para fines académicos y demostrativos.

9. Descripción de las actividades

9.1 Funciones

Funciones mínimas del sistema y del equipo

- Publicar una aplicación o servicio web accesible desde internet.
- Implementar una capa perimetral de protección.
- Filtrar o bloquear solicitudes sospechosas según reglas definidas.
- Registrar eventos, solicitudes bloqueadas o patrones detectados.
- Validar el acceso normal de usuarios legítimos.
- Analizar el comportamiento del WAF frente a pruebas controladas.
- Documentar arquitectura, configuración, incidentes y resultados.

9.1.1 Diseño conceptual

El sistema sigue el siguiente flujo conceptual:

Usuario legítimo o tráfico externo

→ **Capa perimetral / WAF**

→ **Inspección y evaluación de reglas**

→ **Permitir, desafiar, limitar o bloquear**

→ **Aplicación web protegida**

El sistema debe contemplar al menos:

- Inspección del tráfico entrante.
- Aplicación de reglas definidas por el equipo.
- Protección de rutas o patrones sensibles.
- Evidencias de solicitudes permitidas y bloqueadas.
- Monitoreo básico de incidentes o intentos sospechosos.

9.2 Diseño técnico

Elemento técnico	Descripción
Aplicación protegida	Sitio o servicio web de prueba publicado en internet
WAF / protección perimetral	Servicio administrado o autogestionado para inspección HTTP/HTTPS
Reglas de seguridad	Filtrado por patrones, rate limiting, reglas gestionadas, rutas protegidas
Monitoreo / logs	Consola del proveedor, archivos, capturas, panel de eventos
Pruebas de validación	Solicitudes normales, patrones sospechosos, endpoints críticos
Repositorio	Código, configuraciones, scripts, documentación y evidencias
Seguridad complementaria	HTTPS, ocultamiento de origen cuando aplique, control básico de acceso

9.3 Fases del proyecto y distribución por semanas

9.3.1 Resumen de fases

- **Fase 0 – Onboarding y planificación**
- **Fase 1 – Análisis del entorno, riesgos y diseño**
- **Fase 2 – Implementación del entorno protegido y configuración del WAF**
- **Fase 3 – Validación, pruebas y refinamiento**
- **Fase 4 – Cierre técnico y entrega profesional**

9.3.2 Plan de trabajo semanal (visión operativa)

Semana	Fase	Actividades principales del equipo	Entregables asincrónicos esperados

1	Fase 0 – Onboarding	Asignación de roles, creación del repositorio, canal de comunicación y plan de recursos tecnológicos.	Plan de Recursos, enlaces de trabajo, roles registrados en bitácora.
2	Fase 1 – Análisis del entorno	Análisis del escenario, activos expuestos, riesgos y amenazas web relevantes.	Documento de análisis de riesgos y superficie de exposición.
3	Fase 1 – Diseño técnico	Diseño de arquitectura perimetral, flujo del tráfico y definición de reglas iniciales.	Documento de diseño de arquitectura y estrategia WAF.
4	Fase 2 – Publicación del servicio	Implementación o despliegue de la aplicación web de prueba.	Aplicación accesible y repositorio actualizado.
5	Fase 2 – Configuración del WAF	Integración del WAF o proxy seguro, activación de reglas iniciales.	WAF configurado y primeras evidencias de funcionamiento.
6	Fase 3 – Pruebas iniciales	Pruebas de acceso normal y solicitudes sospechosas controladas.	Matriz de pruebas y resultados preliminares.
7	Fase 3 – Ajuste de reglas	Refinamiento de reglas, mitigación de falsos positivos y mejoras de protección.	Reglas ajustadas y evidencias comparativas antes/después.
8	Fase 3 – Monitoreo y evidencias	Organización de logs, capturas, eventos detectados y análisis de comportamiento.	Consola o evidencias de monitoreo documentadas.
9	Fase 4 – Cierre técnico	Redacción del borrador del informe, diagramas finales y cierre de configuración.	Borrador de informe final y documentación técnica consolidada.
10	Fase 4 – Entrega profesional	Informe final, demo y exposición del funcionamiento de la protección perimetral.	Informe final, demo, bitácora y evidencias completas.

9.4 Plan de Recursos Tecnológicos (específico del proyecto)

9.4.1 Plantilla de Plan de Recursos

Recurso	Proveedor / Plataforma	Responsable	Tipo / Plan	Uso previsto en el proyecto	Límites / Observaciones
Aplicación web de prueba	Vercel / Render / Firebase / VM / otro	Desarrollador Web Jr.	Free tier / educativo	Publicar el servicio que será protegido por la capa perimetral.	Debe ser simple, funcional y documentado.

Servicio WAF	Cloudflare / AWS WAF / Azure WAF / ModSecurity / otro	Ingeniero de Seguridad Cloud Jr.	Free / trial / educativo	Filtrar y proteger tráfico web entrante.	Verificar límites del plan y tipos de reglas disponibles.
Proxy inverso / gateway	Nginx / servicio administrado	Ingeniero de Seguridad Cloud Jr.	Free / autogestionado	Encaminamiento del tráfico y endurecimiento perimetral.	Documentar puertos, TLS y configuración.
DNS / CDN	Cloudflare / proveedor cloud	Ingeniero de Infraestructura Jr.	Free tier	Exponer dominio, enrutamiento y protección adicional.	Cuidar la trazabilidad del origen y DNS correcto.
Repositorio de código	GitHub / GitLab	Líder de proyecto Jr.	Free	Versionar código, configuraciones y documentos.	No subir secretos ni credenciales.
Herramientas de pruebas	Navegador, curl, Postman, scripts propios	QA / Analista de Seguridad Jr.	Free	Ejecutar validaciones funcionales y de tráfico controlado.	Evitar pruebas destruktivas o fuera del alcance académico.
Evidencias y documentación	Google Docs / PDF / capturas / bitácora	Documentador Jr.	Institucional / free	Consolidar informe, matriz de pruebas y evidencias.	Mantener orden, fechas y trazabilidad.
Canal de comunicación	WhatsApp / Teams / Discord	Líder de proyecto Jr.	Free	Coordinar trabajo asincrónico del equipo.	Registrar acuerdos relevantes en bitácora.

9.5 Entregables por fase (vista operativa)

9.5.1 Fase 1 – Análisis y diseño

Documento de Análisis, que incluya:

- Descripción del cliente y contexto institucional.
- Identificación del activo web a proteger.
- Análisis básico de amenazas y riesgos.
- Identificación de superficie expuesta.

- Justificación del uso de un WAF en el escenario.

Documento de Diseño, que incluya:

- Arquitectura general de protección perimetral.
- Flujo del tráfico desde el cliente hasta la aplicación.
- Componentes cloud utilizados.
- Estrategia de reglas iniciales del WAF.
- Criterios de monitoreo y validación.

9.5.2 Fase 2 – Implementación del entorno protegido

- Aplicación web desplegada y accesible.
- Integración del WAF o capa perimetral.
- Reglas iniciales configuradas.
- Capturas o evidencias de la consola o configuración.
- Registro de decisiones técnicas y ajustes realizados.

9.5.3 Fase 3 – Validación de seguridad y pruebas

- Matriz de pruebas con escenarios legítimos y sospechosos.
- Evidencias de solicitudes permitidas y bloqueadas.
- Ajustes de reglas y reducción de falsos positivos.
- Registro de eventos relevantes.
- Refinamiento de la solución perimetral.

9.5.4 Fase 4 – Cierre y entrega

Informe Profesional Final, con:

- Contexto del problema.
- Arquitectura final de seguridad perimetral.
- Descripción del servicio protegido y del WAF implementado.
- Reglas aplicadas y su finalidad.
- Resultados de pruebas y evidencias.
- Reflexiones sobre buenas prácticas de ciberseguridad cloud.
- Recomendaciones de mejora futura.

Demo del sistema, mostrando:

- Aplicación publicada.
- Capa WAF en funcionamiento.

- Ejemplos de tráfico permitido.
- Ejemplos de solicitudes detectadas o bloqueadas.
- Evidencias de logs, eventos o panel de control.

9.6 Evidencias asincrónicas esperadas

- **Commits** significativos y atribuibles por integrante.
- Capturas de:
 - despliegue de la aplicación,
 - configuración del WAF,
 - reglas activas,
 - eventos o bloqueos,
 - funcionamiento normal del servicio.
- Bitácora con:
 - decisiones de arquitectura,
 - problemas encontrados,
 - ajustes realizados,
 - análisis de pruebas,
 - distribución real del trabajo.
- Documentación técnica y funcional ordenada.
- Evidencias individuales claramente atribuibles para evaluación personal.

9.7 Evaluación específica del proyecto (vista de rúbrica base)

Este proyecto adopta como estándar la estructura de evaluación específica definida para los proyectos, incorporando tanto la **evaluación grupal** como la **evaluación individual**.

9.7.1 Dimensiones de la evaluación grupal

Dimensión grupal	Aspectos a evaluar
Calidad técnica de la solución	Funcionamiento general de la protección perimetral, correcta implementación del WAF, coherencia técnica entre aplicación, reglas, monitoreo y resultados de pruebas, estabilidad del entorno y pertinencia de las tecnologías utilizadas.
Gestión del proyecto	Cumplimiento de fases, organización del trabajo grupal, calidad del repositorio, orden de entregables, actualización de bitácora y evidencias de avance.
Integración y trabajo en equipo	Coordinación grupal, claridad en la distribución de roles, articulación de aportes y coherencia del resultado final como producto colectivo.

Documentación, evidencias y presentación	Calidad del informe final, claridad de la documentación técnica, organización de evidencias, calidad de la demostración funcional y nivel profesional de la presentación del proyecto.
---	--

Ponderación sugerida de la nota grupal

- **35 % Calidad técnica de la solución**
- **25 % Gestión del proyecto**
- **20 % Integración y trabajo en equipo**
- **20 % Documentación, evidencias y presentación**

Criterio de aplicación

La rúbrica grupal se aplicará como base común del proyecto. En este caso, la dimensión técnica se interpretará específicamente sobre los elementos centrales de la propuesta: **seguridad perimetral, filtrado de tráfico, reglas WAF, protección del servicio cloud, monitoreo de eventos y evidencia de mitigación.**

9.7.2 Dimensiones de la evaluación individual

Dimensión individual	Aspectos a evaluar por estudiante
Desempeño técnico individual	Calidad del trabajo técnico realizado en el área asignada, resolución de problemas, aporte técnico verificable en configuración, pruebas, documentación o integración.
Cumplimiento y responsabilidad	Entrega oportuna de tareas, seguimiento de acuerdos, constancia en el trabajo y capacidad de respuesta ante ajustes o incidencias.
Trazabilidad de aportes	Evidencias individuales en commits, bitácora, configuraciones, pruebas, reportes, capturas o documentación claramente atribuible al estudiante.
Participación y actitud profesional	Iniciativa, autonomía, comunicación con el equipo, colaboración y comportamiento profesional durante el desarrollo del proyecto.

Ponderación sugerida de la nota individual

- **35 % Desempeño técnico individual**
- **25 % Cumplimiento y responsabilidad**
- **25 % Trazabilidad de aportes**
- **15 % Participación y actitud profesional**

Criterios de evidencia para la nota individual

Se recomienda considerar:

- Commits identificables y significativos.
- Participación documentada en la bitácora.
- Configuraciones o reglas implementadas por el estudiante.
- Evidencias de pruebas ejecutadas.
- Secciones del informe elaboradas o corregidas.
- Capturas o registros atribuibles a tareas específicas.
- Participación verificable en la demo o explicación técnica.

9.8 Tareas detalladas de los estudiantes

9.8.1 Tareas por semana y fase

Semana	Fase	Tareas específicas de los estudiantes
1	Fase 0 – Onboarding y planificación	Leer la descripción del proyecto, definir roles, crear repositorio, canal de comunicación, estructura documental y plan de recursos.
2	Fase 1 – Análisis del entorno	Identificar activos a proteger, amenazas relevantes y objetivos de protección. Redactar el análisis inicial.
3	Fase 1 – Diseño técnico	Diseñar arquitectura perimetral, flujo de tráfico, estrategia de reglas y criterios de monitoreo.
4	Fase 2 – Despliegue de la aplicación	Implementar o desplegar la aplicación web de prueba que será protegida.
5	Fase 2 – Configuración del WAF	Integrar el WAF, crear reglas iniciales, configurar políticas básicas y validar acceso normal.
6	Fase 3 – Pruebas iniciales	Ejecutar pruebas con solicitudes legítimas y escenarios sospechosos controlados.
7	Fase 3 – Ajuste y endurecimiento	Refinar reglas, documentar falsos positivos, ajustar configuraciones y mejorar protección.
8	Fase 3 – Monitoreo y análisis	Organizar evidencias, analizar eventos detectados y documentar comportamiento del sistema.
9	Fase 4 – Cierre técnico	Congelar versión final, elaborar diagramas, consolidar documentación y redactar borrador del informe.
10	Fase 4 – Entrega profesional	Finalizar informe, preparar demo, consolidar evidencias y registrar cierre del proyecto.

9.8.2 Tareas mínimas por rol

Líder de proyecto Jr.

- Coordinar entregas, responsables y seguimiento del cronograma.
- Mantener el backlog de actividades.
- Verificar que la bitácora y evidencias estén completas.

Ingeniero de Seguridad Cloud Jr.

- Diseñar e implementar la capa WAF o de filtrado perimetral.
- Configurar reglas y políticas de seguridad.
- Documentar decisiones técnicas y ajustes realizados.

Ingeniero de Infraestructura Jr.

- Apoyar el despliegue del entorno, DNS, proxy, HTTPS y conectividad.
- Verificar disponibilidad y exposición controlada del servicio.
- Documentar la infraestructura utilizada.

Desarrollador Web Jr.

- Implementar o adaptar la aplicación web de prueba.
- Validar funcionamiento del servicio protegido.
- Apoyar en pruebas funcionales y ajustes de compatibilidad.

Analista QA / Seguridad Jr.

- Diseñar y ejecutar matriz de pruebas.
- Generar tráfico de validación controlado.
- Registrar resultados, falsos positivos y comportamiento del sistema.

Documentador Jr.

- Organizar evidencias, capturas y estructura del informe final.
- Consolidar bitácora y documentación técnica.
- Apoyar la preparación de la demo y presentación final.

10. Resultado esperado del proyecto

Al finalizar, el equipo deberá presentar un **prototipo funcional de seguridad perimetral cloud**, capaz de proteger una aplicación web mediante una capa de **WAF**, mostrando evidencia concreta de:

- arquitectura implementada,
- reglas configuradas,
- tráfico legítimo permitido,
- tráfico sospechoso filtrado o bloqueado,
- monitoreo básico de eventos,
- documentación técnica clara,
- y trabajo colaborativo con trazabilidad individual.